



M1 CYBER · SÉCURITÉ DES SYSTÈMES

Hardening Active Directory

Du risque au déploiement maîtrisé

Auditer, durcir, déployer sans casser la production



Au programme

01

Pourquoi durcir

02

La menace concrète

03

Auditer avant d'agir

04

Le modèle de tiering

05

Mesures techniques

06

Déploiement maîtrisé

07

Atelier HardenAD

08

Synthèse

PARTIE 01

Pourquoi durcir l'AD ?

Le hardening n'est pas une fin en soi.

Qu'est-ce que le hardening AD ?

Réduire la surface d'attaque d'Active Directory en supprimant les configurations risquées et en restreignant les privilèges au strict nécessaire.

Réduire la surface

Moins de comptes à privilèges, moins de protocoles hérités, moins de droits délégués au hasard = moins de portes d'entrée pour l'attaquant.

Un processus continu

La sécurité d'un AD se dégrade dans le temps, au rythme des délégations et des exceptions. Le hardening se ré-audite, il ne se fait pas une fois pour toutes.

La règle d'or : le risque commande

1

On part du risque

On ne durcit pas une option parce qu'elle existe, mais parce qu'un scénario d'attaque réel la rend dangereuse ici.

2

On confirme par l'audit

Un outil prouve que le risque est présent sur CET annuaire avant toute action. Jamais de remédiation à l'aveugle.

3

On déploie par paliers

Pilote, retour arrière testé, élargissement progressif. Le durcissement ne doit jamais casser la production.

Ne jamais durcir « pour durcir » : chaque mesure neutralise un risque identifié.

PARTIE 02

La menace concrète

Comprendre l'attaque pour choisir la bonne défense.

Active Directory : la cible n°1



L'AD centralise l'authentification et les autorisations de tout le SI. Le compromettre, c'est obtenir les clés du royaume.

Centralité

Comptes, postes, serveurs, GPO : tout passe par l'AD. Une compromission du domaine, c'est un contrôle total du SI.

Déplacement latéral

Depuis un simple poste compromis, l'attaquant rebondit de compte en compte jusqu'à atteindre le tier 0.

Techniques d'attaque courantes

1

Kerberoasting

Demande de tickets de service puis cassage hors-ligne des mots de passe faibles des comptes de service.

2

Déplacement latéral

Pass-the-Hash / Pass-the-Ticket : réutilisation de secrets volés pour rebondir sans connaître le mot de passe.

3

Escalade de privilèges

Exploitation d'ACL trop permissives ou de délégations mal maîtrisées pour atteindre Domain Admins.

Chaque technique correspond à une faiblesse de configuration... donc à un contrôle.

Du chemin d'attaque au contrôle

Technique	Faiblesse exploitée	Contrôle de durcissement
Kerberoasting	Mots de passe de service faibles	Comptes gMSA, mots de passe longs
Pass-the-Hash	Admin local réutilisé partout	LAPS + cloisonnement en tiers
DCSync	Droits de réplication mal délégués	Auditer / retirer les droits Replicating
Escalade par ACL	GenericAll, WriteDACL	Nettoyage des ACL dangereuses

À chaque ligne du rapport d'audit doit correspondre un contrôle précis.

Repérer une faiblesse côté défense

Exemple : lister les comptes « kerberoastables » — un SPN posé sur un compte utilisateur.

POWERSHELL · MODULE ActiveDirectory

```
# Comptes de service exposés au Kerberoasting
Get-ADUser -Filter "ServicePrincipalName -like '*' " `
  -Properties ServicePrincipalName, PasswordLastSet

# -> un mot de passe de service faible = cible directe
```

Auditer, c'est déjà voir l'AD avec les yeux de l'attaquant — dans un cadre autorisé.

PARTIE 03

Auditer avant d'agir

Confirmer le risque par la mesure, pas par l'intuition.

Les outils d'audit incontournables

1

PingCastle

Score de santé AD de 0 à 100, cartographie des trusts, règles pondérées alignées ANSSI. Tourne hors-ligne.

2

BloodHound

Cartographie les chemins d'attaque : qui peut atteindre Domain Admins, et par quelle suite de rebonds.

3

Purple Knight

Évaluation orientée indicateurs d'exposition et de compromission, complémentaire de PingCastle.

Outils dual-use : à n'utiliser que dans un cadre explicitement autorisé.

Lire un rapport PingCastle



Le score va de 0 (sain) à 100 (très risqué). Ce n'est pas une note d'examen : c'est une carte de priorités.

Prioriser

Trier les findings par risque réel et par exploitabilité, pas par la couleur affichée dans le rapport.

Tracer dans le temps

Re-mesurer le score après chaque vague de remédiation pour prouver le progrès et détecter les régressions.

Prioriser la remédiation

À NE PAS FAIRE

- Tout durcir d'un coup parce que l'outil l'a signalé.
- Appliquer 89 recommandations sans contexte métier.
- Ignorer l'exploitabilité réelle des findings.

BONNE PRATIQUE

- Traiter d'abord ce qui casse un chemin d'attaque réel.
- Mapper chaque action à un risque et à un référentiel.
- Mesurer l'impact avant de généraliser.

PARTIE 04

Le modèle de tiering

La colonne vertébrale de tout durcissement (reco ANSSI).

Le cloisonnement en tiers



Tier 0

Cœur du SI : contrôleurs de domaine et comptes d'administration du domaine. Actions rares, ultra-protégées.



Tier 1

Serveurs et applications métier. Administrés par des comptes dédiés, jamais par des comptes du tier 0.



Tier 2

Postes de travail et utilisateurs. Le niveau le plus exposé, strictement isolé des tiers supérieurs.

Règle d'or : un compte d'un tier ne s'authentifie jamais sur un tier inférieur.

Le réseau ne suffit pas



Beaucoup comptent sur la segmentation réseau pour cloisonner l'AD. Or l'AD exige des protocoles (Kerberos, SMB, RPC) que le pare-feu laisse passer sans en contrôler le contenu.

Le vrai périmètre

Le périmètre de sécurité minimal d'une architecture AD, c'est la forêt — pas le sous-réseau.

Cloisonnement logique

Silos d'authentification, GPO de restriction d'ouverture de session, comptes dédiés par tier.

Pratiques d'administration

À NE PAS FAIRE

- Se connecter à un poste utilisateur avec un compte Domain Admin.
- Comptes d'administration permanents et partagés.
- Même mot de passe d'admin local sur toutes les machines.

BONNE PRATIQUE

- Postes d'administration dédiés (PAW), un par tier.
- Comptes nominatifs, privilèges temporaires (just-in-time).
- Mots de passe d'admin local uniques et gérés (LAPS).

PARTIE 05

Mesures techniques

Ce que l'on durcit concrètement.

Mesures de durcissement courantes

Mesure	Pourquoi	Effet de bord à surveiller
Désactiver SMBv1	Protocole obsolète, vecteur de propagation	Vieux NAS, imprimantes, scanners
Couper LLMNR / NBT-NS	Empoisonnement et vol d'empreintes	Résolution de noms héritée
Signer LDAP / LDAPS	Empêche relais et écoute passive	Applis liées en LDAP simple
Déployer LAPS	Stoppe la réutilisation d'admin local	Outils supposant un MDP fixe

Chaque mesure technique vient avec son effet de bord : on l'anticipe, on ne le découvre pas.

Trois chantiers prioritaires

1

Comptes à privilèges

Réduire le nombre de Domain Admins, supprimer les comptes dormants, activer l'audit des authentications.

2

Protocoles hérités

Désactiver SMBv1, LLMNR, NTLMv1 ; forcer la signature LDAP côté contrôleurs de domaine.

3

Secrets locaux

Déployer LAPS pour des mots de passe d'administrateur local uniques et renouvelés automatiquement.

Exemple : durcir une machine

Deux gestes simples, toujours accompagnés d'un test et d'un plan de retour arrière.

POWERSHELL

```
# Désactiver SMBv1 (vecteur de propagation historique)
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol

# Vérifier la signature LDAP exigée côté contrôleur de domaine
Get-ADObject -SearchBase (Get-ADRootDSE).configurationNamingContext ...

# Toujours tester en lab avant la production
```

Une commande de durcissement va toujours avec son test et son retour arrière.

PARTIE 06

Déploiement maîtrisé

Durcir sans casser la production.

Trois réflexes de déploiement

1

Effets de bord

Cartographier les dépendances : une appli legacy peut tomber dès qu'on coupe un protocole hérité.

2

Réversibilité

Sauvegarde des GPO, snapshots, system state, corbeille AD. Un rollback testé AVANT d'appliquer.

3

Conduite du changement

Prévenir les utilisateurs et le support. La résistance se gère, elle ne se subit pas.

Écrire le plan de retour arrière fait partie de la remédiation, pas de l'après.

Déploiement en anneaux



Critères de passage explicites entre chaque anneau : aucun effet de bord bloquant.

PARTIE 07 · ATELIER

Appliquer avec HardenAD

Mettre la théorie en pratique avec un outil GitHub réputé.

HardenAD



Projet open source (français) qui automatise le déploiement d'un modèle d'administration sécurisé, aligné sur les recommandations ANSSI et Microsoft.

Ce qu'il déploie

Structure d'OU en tiers, GPO de durcissement, groupes et comptes d'administration cloisonnés.

Pourquoi c'est utile

Il industrialise le tiering : des semaines de travail manuel deviennent un déploiement scripté et reproductible.

Qualifier un outil GitHub avant exécution

À NE PAS FAIRE

- Exécuter un script inconnu en Domain Admin sur un contrôleur de domaine.
- Lancer le code directement en production sans relecture.
- Faire confiance au seul nombre d'étoiles GitHub.

BONNE PRATIQUE

- Lire le code, vérifier l'éditeur et les signatures ou empreintes.
- Tester d'abord dans un lab isolé.
- Exécuter au moindre privilège nécessaire, jamais plus.

Déployer HardenAD pas à pas

L'outil applique vite ce qu'on a compris lentement : la maîtrise reste humaine.

ATELIER · À FAIRE EN LAB

- # 1. Récupérer le projet depuis le dépôt officiel
`git clone https://github.com/<éditeur>/HardenAD.git`
- # 2. Vérifier : relire le code, contrôler le hash / la signature
- # 3. Adapter la configuration (XML) à votre modèle de tiers
- # 4. Lancer dans le LAB d'abord, en tier 0 contrôlé
- # 5. Valider, re-scanner avec PingCastle, puis élargir par anneaux

Suivre la documentation officielle pour la procédure exacte de votre version.



Ce qu'il faut retenir

01

Le risque commande

On ne durcit pas pour durcir. Chaque mesure neutralise un risque confirmé par l'audit.

02

Le tiering est la base

Sans cloisonnement en tiers, le durcissement objet par objet reste fragile.

03

Déployer sans casser

Anneaux progressifs, rollback testé, mesure dans le temps : la production d'abord.